SECCIÓN 4.1

# Tipos de malware y amenazas comunes

**Temas de esta sección:**

- Malware desde una mirada SOC: qué busca hacer, no solo qué es
- Diferencia entre malware, amenaza y comportamiento
- 17 tipos: virus, worm, troyano, ransomware, spyware, keylogger, infostealer...
- RAT, backdoor, downloader, dropper, botnet, rootkit, wiper, cryptominer
- Adware, PUA y fileless malware
- Cómo aparece cada tipo en alertas SOC y qué revisar

**Malware** es software o código diseñado para realizar acciones no autorizadas, dañinas o abusivas. Lo importante es entender **qué hizo, qué intenta hacer y qué riesgo representa.**

## Una alerta en SOC puede decir:

```
Malware detected
```

```
Trojan.Generic
```

```
Ransomware behavior detected
```

```
Suspicious PowerShell
```

```
Possible credential theft
```

```
Backdoor activity
```

## El analista debe preguntarse:

- ¿Qué tipo de amenaza podría ser?
- ¿Qué intenta hacer?
- ¿Está bloqueado o ejecutado?
- ¿Qué evidencia necesito revisar?
- ¿Qué impacto podría tener?
- ¿Hay actividad posterior?

Están relacionados, pero no son lo mismo. En SOC muchas veces vemos comportamientos, no 'el malware completo'.

| | | |
|---|---|---|
| **MALWARE** | Código o software malicioso. | *Ejemplo: Un ejecutable que roba credenciales.* |
| **AMENAZA** | Actividad, actor o condición que puede causar daño. | *Ejemplo: Una campaña de phishing que distribuye malware.* |
| **COMPORTAMIENTO** | Acciones observables en logs o alertas. | *Ejemplo: PowerShell descarga un archivo, crea persistencia y se conecta a un dominio externo.* |

***En SOC muchas veces no vemos 'el malware completo'. Vemos comportamientos que pueden indicar un tipo de malware o una etapa del ataque.***

No todo malware se manifiesta de la misma forma. El tipo cambia el comportamiento esperado y la evidencia a buscar.

| MALWARE RUIDOSO — busca impacto rápido | MALWARE SILENCIOSO — busca mantenerse oculto |
|---|---|
| Ransomware behavior detected | Browser cookies accessed |
| Mass file encryption | Small HTTPS upload (3KB) |
| Shadow copies deleted | New scheduled task |
| Services stopped | Periodic connection every 60 seconds |
| Disk overwrite activity | Signed-looking binary in AppData |

*El malware silencioso puede ser más difícil de detectar pero igualmente peligroso. Un analista que solo presta atención a alertas 'ruidosas' puede perder actividades de espionaje, robo de credenciales o preparación de exfiltración.*

# 4.1 | 17 tipos de malware: visión general

Cada tipo tiene objetivos distintos. Entender qué busca hace cada uno define qué evidencia buscar:

| Tipo | Objetivo principal | Señales en SOC |
|---|---|---|
| **Virus** | Infecta archivos y se propaga | *File infected, Multiple files modified* |
| **Worm** | Propagación automática en red | *SMB to many hosts, Same file on many endpoints* |
| **Troyano** | Se disfraza de algo legítimo | *Exec from Downloads, Outbound connection* |
| **Ransomware** | Cifra archivos y pide rescate | *Mass file rename, Shadow copies deleted* |
| **Spyware** | Espía actividad del usuario | *Screen capture, Browser data access* |
| **Keylogger** | Registra teclas del usuario | *Keyboard monitoring, Outbound upload* |
| **Infostealer** | Roba credenciales y cookies | *Chrome Login Data accessed, data.zip created* |
| **RAT** | Acceso remoto no autorizado | *Persistent outbound connection, Remote cmd exec* |
| **Backdoor** | Mantiene acceso alternativo | *New service, Listening port, Local admin created* |
| **Downloader** | Descarga otro payload | *PowerShell downloads file, File in Temp/Public* |
| **Dropper** | Instala otro componente | *Executable creates executable, Child process* |
| **Botnet** | Controla equipos en red | *Periodic C2, Same destination many hosts* |
| **Rootkit** | Oculta actividad maliciosa | *Driver alert, EDR tamper, Hidden process* |
| **Wiper** | Destruye información | *Mass deletion, MBR modification, Systems down* |
| **Cryptominer** | Usa recursos para minar | *High CPU, xmrig.exe, Mining pool connection* |
| **Adware/PUA** | Publicidad y apps no deseadas | *Browser extension, Search redirect, PUA detected* |
| **Fileless** | Opera sin archivo en disco | *PS encoded cmd, WMI subscription, LOLBin abuse* |

# 4.1 | Ransomware: el más visible — Infostealer: el más peligroso

Dos de los tipos más importantes para el analista SOC moderno:

## RANSOMWARE

```
Alert: Ransomware behavior detected
Host: FILE-SRV-02  |  User: svc_backup
- 12,000 files renamed
- Extension changed to .locked
- vssadmin.exe Delete Shadows
- ransom_note.txt created
```

Acción: Escalamiento INMEDIATO. Revisar hosts afectados, actividad previa de movimiento lateral y exfiltración.

Impacto: Confidencialidad + Integridad + Disponibilidad

## INFOSTEALER

```
Alert: Possible credential theft
Host: USER-LAP-088  |  User: ventas.mora
Process: update_service.exe
Accessed: Chrome Login Data, Cookies
Created: collected.zip
Network: upload to files-check-storage.net
```

Acción: Escalar. Revisar logins posteriores, sesiones activas y cuentas potencialmente comprometidas.

Impacto: Confidencialidad — puede afectar sistemas externos

# 4.1 | Mini escenarios: tres tipos, tres análisis distintos

El tipo de malware define qué evidencia buscar y qué acción tomar:

**Troyano + Downloader + posible C2**

```
Host: USER-LAP-044  User: compras.vera
invoice_update.exe desde Downloads
→ Archivo creado en AppData
→ Scheduled task creado
→ sync-check-cloud.net cada 60s
```

*→ Escalar. Secuencia compatible con ejecución inicial, persistencia y posible C2.*

**Ransomware en FILE-SRV-02**

```
svc_backup → 18,000 archivos renombrados
Extensión: .encrypted
vssadmin.exe Delete Shadows
ransom_note.txt creado
```

*→ Escalamiento inmediato. Revisar movimiento lateral previo.*

**Infostealer + Exfiltración**

```
ventas.mora → system_update.exe
Accedió: Chrome Login Data + Cookies
Creó: collected.zip
Subió a: files-check-storage.net
```

*→ Escalar. Revocar sesiones. Revisar logins posteriores.*